Chapter 2

Reconnaissance, Footprinting and OSINT

Theory: 2 Hours **Practice:** 2 Hours

Instructor: Dr. Brahim Ferik

Academic Year: 2026–2027

1 Reconnaissance, Footprinting and OSINT

Reconnaissance is the disciplined collection and interpretation of information about an **authorized target** before intrusive technical testing begins. It converts a limited scope into a clearer picture of the systems, people, technologies, and external relationships that may be relevant to the assessment. Information gathering appears early in penetration-testing methodologies because later decisions depend on the quality of this initial understanding [1].

The purpose is not to gather the largest possible dataset. A good assessment answers a defined security question, distinguishes evidence from inference, and identifies which assets can be assessed under the Rules of Engagement. By the end of this chapter, students should be able to distinguish passive and active techniques, develop a structured footprint, use public intelligence services and defensive search queries, assess source reliability, and prepare a concise reconnaissance report.

For this course, three related terms are distinguished:

- **Reconnaissance** is the broad information-gathering activity used to understand a target.
- **Footprinting** is the construction of a structured target profile from the collected information.
- **Open-Source Intelligence (OSINT)** is the collection, processing, correlation, and validation of information obtained from openly accessible sources for a defined intelligence purpose.

A target footprint may include registered domains, DNS infrastructure, publicly visible services, organizational locations, employee roles, email-address conventions, public repositories, documents, technologies, suppliers, and third-party services. These observations

are useful only when they are interpreted carefully. A hostname, software reference, email address, or old document is an investigative lead; it does not by itself prove ownership, current use, or vulnerability.

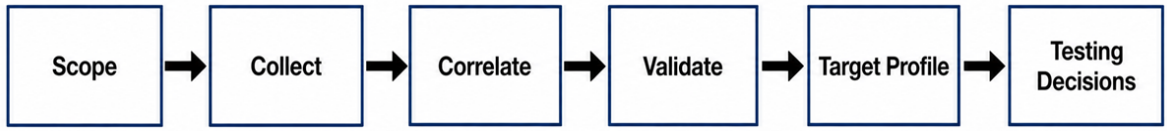


Figure 1: Reconnaissance workflow from scope definition through collection, correlation, validation, target profiling, and testing decisions.

MITRE ATT&CK treats Reconnaissance as a pre-compromise tactic and includes activities such as gathering network, identity, and organizational information and searching open websites and technical databases [4].

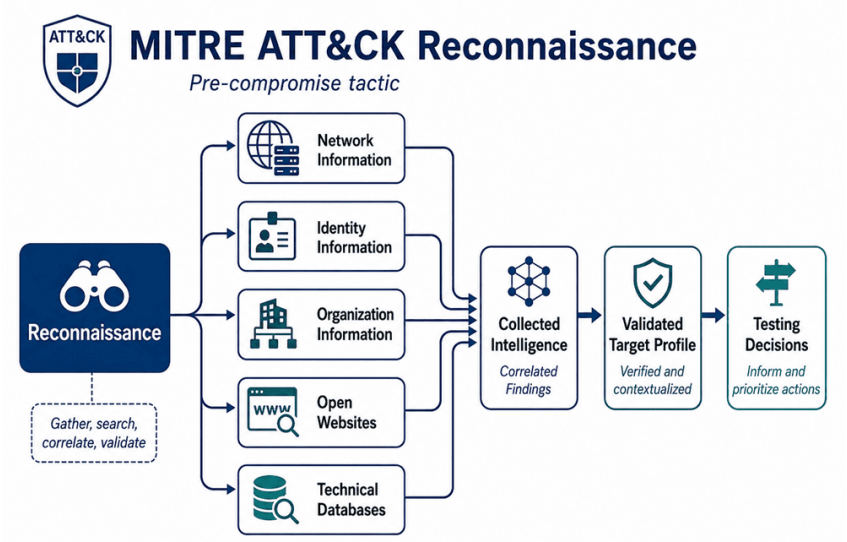


Figure 2: Reconnaissance transforms an authorized scope into a validated target profile that supports later testing decisions.

2 Passive, Low-Touch and Active Reconnaissance

Reconnaissance may occur without target contact or through direct requests. Its operational classification depends primarily on the degree of interaction with infrastructure controlled by the target.

Passive reconnaissance reduces direct contact with the target, but it is not anonymous. Search engines, OSINT platforms, API providers, and other third parties may log queries and account activity.

Active reconnaissance can create target-side logs, alerts, or performance impact. It therefore requires explicit authorization and clear Rules of Engagement [5]. Detailed port scanning, Nmap, service enumeration, and vulnerability scanning are intentionally left to the later scanning chapter. Google dorking, by contrast, is treated here as search-engine reconnaissance rather than as an exploitation method.

Level	Interaction	Typical Examples
Passive / Indirect	No deliberate interaction with target infrastructure	Search engines, RDAP, passive DNS, certificate databases, public repositories, web archives, Shodan, Censys, and breach-notification services
Low-Touch	Normal use of a public target resource	Browsing the public website, retrieving an authorized public document, or performing normal DNS resolution
Active	Purposeful technical probing of the target	Host discovery, port scanning, service enumeration, application fingerprinting, and vulnerability scanning

Table 1: Practical interaction levels for reconnaissance.

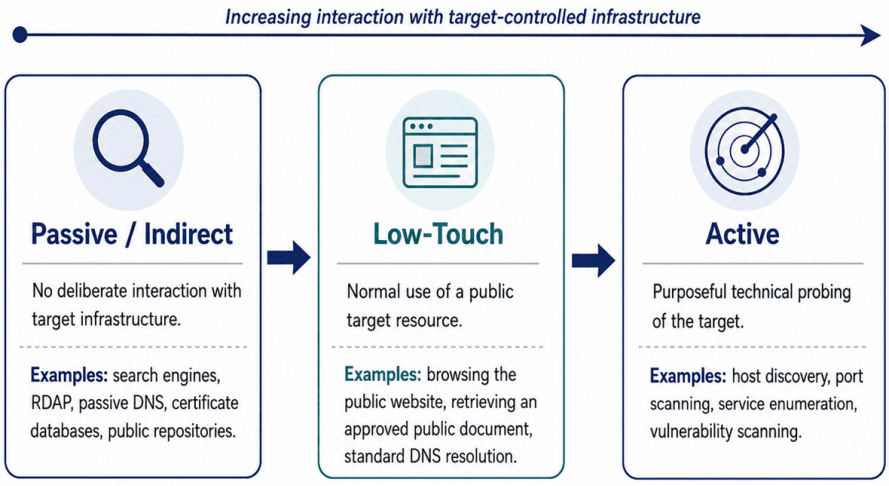


Figure 3: Passive, low-touch, and active reconnaissance differ primarily in the degree of interaction with target-controlled infrastructure.

3 A Practical OSINT Workflow

Effective OSINT is a process, not a collection of websites. Unstructured searching often produces large quantities of stale, irrelevant, or misattributed information. A concise workflow is:

1. **Define the intelligence question.** Decide what must be learned and confirm that it is within scope.
2. **Collect selectively.** Use sources that are appropriate to the question rather than gathering unnecessary personal information.
3. **Process and normalize.** Remove duplicates, standardize names and dates, and group findings by type.
4. **Correlate.** Compare independent observations to identify relationships among domains, infrastructure, technologies, people, and third parties.

5. **Validate.** Check ownership, freshness, source quality, and alternative explanations.
6. **Document.** Record the source, collection date, relevance, confidence, and any uncertainty.

3.1 Validation and Confidence

Professional reconnaissance requires corroboration. An official registry, authoritative DNS response, or organization-owned publication generally carries more weight than an anonymous post or an automated aggregation. Historical information remains useful, but it must be labelled as historical.

For this course, a simple confidence scale is sufficient:

High Supported by an authoritative source or several independent, current observations.

Medium Plausible and supported by some evidence, but additional confirmation is desirable.

Low Old, indirect, weakly attributed, or uncorroborated.

A useful rule is to separate **observation** from **conclusion**. For example, a job advertisement mentioning a cloud platform is evidence that the organization values that skill; it is not proof that the platform is currently used in production.

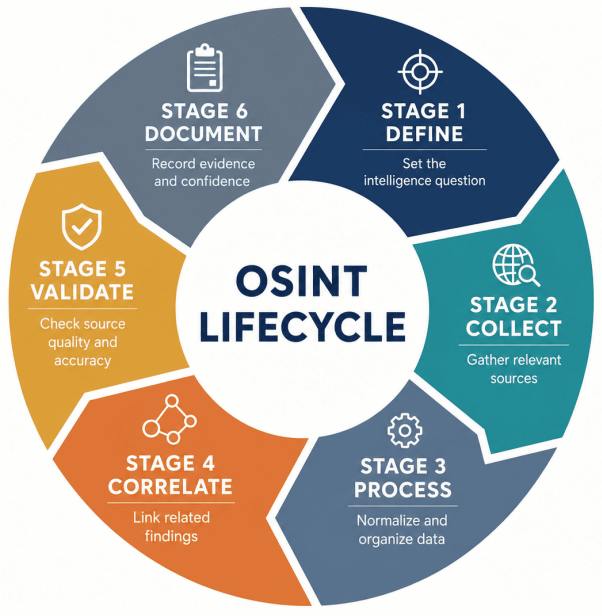


Figure 4: A compact OSINT lifecycle: define, collect, process, correlate, validate, and document.

4 Core Reconnaissance Sources

No single source provides a complete view of an organization. Strong footprinting combines several classes of information and looks for consistent relationships among them.

4.1 Domain Registration and RDAP

Domain registration information helps determine whether a domain is plausibly associated with the target and may reveal the registrar, registration dates, status codes, and authoritative name servers. Historically this information was associated with WHOIS. For generic top-level domains, ICANN designated **RDAP** as the definitive registration-data service beginning on 28 January 2025 [6].

Students should therefore understand both terms:

WHOIS: legacy registration-data protocol. RDAP: structured replacement for gTLD lookup.

Registration data is an investigative lead rather than absolute proof of ownership, and personal registrant details may legitimately be redacted.

4.2 DNS and Certificate Information

DNS reveals how an organization publishes names and services [7]. The most useful records can be summarized compactly:

Record	Purpose	Reconnaissance Value
A / AAAA	Name to IPv4 / IPv6 address	Associates names with public addressing
MX	Mail exchange	Identifies public email infrastructure
NS	Name server delegation	Identifies DNS providers and delegation
CNAME	Alias to another name	May reveal SaaS, CDN, or hosting relationships
TXT	Arbitrary text	Often includes verification and email-security data
SOA / PTR	Zone administration / reverse name	Supports infrastructure correlation

Table 2: Key DNS records for reconnaissance.

Certificate Transparency and certificate-search services can reveal hostnames and relationships that are not obvious from a public website. Certificate information should be correlated with DNS and organizational evidence because certificates can be old, shared, or associated with retired services.

4.3 Web, Organizational and Historical Sources

Organization-owned websites, public reports, job advertisements, press releases, support portals, code repositories, and archived pages can reveal business units, office locations, technology terminology, suppliers, naming conventions, and historical exposure.

Recruitment material is especially useful for generating technology hypotheses, but it should never be treated as definitive proof of a production environment. Similarly, a supplier or partner named on a website does not automatically become part of the authorized penetration test.

4.4 Documents and Metadata

Public PDF files, presentations, office documents, and images may contain metadata such as author names, timestamps, software names, document properties, embedded usernames, or—for some images—location data. Metadata can therefore expose technical or organizational clues that are not visible in the document body.

ExifTool is a widely used utility for reading metadata from many file formats. In the laboratory it should be used only on instructor-provided files or public documents explicitly approved for the exercise. Metadata produces leads, not certainty: an embedded username may belong to a former employee, and a software version may describe only the workstation used to create the document. OWASP likewise treats content and metadata review as part of information gathering [8, 3].

5 Search-Engine Reconnaissance and Google Dorking

Search engines index public web pages, documents, and references that organizations may not realize are easy to discover. **Google hacking**, more precisely called **Google dorking**, uses advanced search syntax to query those indexes. Despite the name, it does not exploit Google or bypass a website's authentication. It reveals what a search provider has already found and associated with the query [9, 2].

In ethical hacking, the guiding question is: *What could an external observer learn about an approved organization through ordinary search facilities?* The method is passive with respect to the target when the analyst reviews search results supplied by a third-party search service. Visiting a returned page is a separate interaction and may be low-touch.

5.1 How Search Exposure Arises

A search provider generally discovers URLs through links and sitemaps, fetches permitted content, and constructs an index. Indexing does not mean that the organization intended a file to be public; an obsolete report, development notice, or uploaded PDF may have remained reachable long enough to be indexed. Conversely, a missing search result does not prove that a resource is secure or unavailable. Search results reflect crawl schedules, search-engine ranking, and indexing policies rather than a complete inventory of every public file.

This distinction matters when interpreting findings. A document title in a result is an **observation**. Establishing whether the resource is still accessible, sensitive, associated with the organization, and within the agreed scope is the **analysis**. A search listing by itself does not prove a security vulnerability.

5.2 Core Search Operators

The operators below provide sufficient precision for an introductory reconnaissance exercise. Syntax and support may change, so students should check current provider documentation [11, 9].

Syntax	Function	Safe illustrative query
`site:`	Restricts search to a website or domain	`site:owasp.org testing`
`"phrase"`	Matches an exact phrase	`"security testing guide"`
`filetype:`	Limits results to a document format	`site:owasp.org filetype:pdf`
`intitle:`	Finds a term in a page title	`site:owasp.org intitle:testing`
`inurl:`	Finds a term in a URL	`site:owasp.org inurl:project`
`-term`	Excludes a word or phrase	`security guidance -advertising`
`after:` / `before:`	Applies date constraints supported by the engine	`site:owasp.org after:2024-01-01`

Table 3: Selected search operators for authorized reconnaissance. Examples use public educational information; operators and indexing behavior may vary by provider.

5.3 Composing Focused, Defensive Queries

The simplest query establishes an approximate indexed footprint:

```
site:owasp.org
```

A document-oriented search narrows the results:

```
site:owasp.org filetype:pdf
```

Combining a domain constraint, content type, and relevant phrase often produces a more useful collection set than searching for a company name alone. For example, an instructor-approved training site might be examined for public policy documents:

```
site:training.example.org filetype:pdf "policy"
```

The final query is *illustrative*: `example.org` is a reserved documentation domain, not a live training target. Students must substitute a genuinely approved domain when permitted by the instructor.

A professional search uses a progression: begin with broad organization terms, restrict by an approved domain, refine by file type or topic, review the result metadata, and collect only the evidence needed. Query selection must follow a legitimate intelligence objective. Searching unrelated sites for credentials or private personal information is not part of this laboratory.

5.4 Google Hacking Database and Search Limitations

The **Google Hacking Database (GHDB)** is a public collection of search patterns associated with different classes of information exposure. It can help defenders understand the sorts of content that search operators may reveal. Its entries should be treated as *research patterns*, not instructions to access unrelated systems or download confidential material [9, 14].

Google, Bing, and other engines do not necessarily interpret identical operators in the same way, and no search engine indexes everything. A sound assessment may compare supported sources, but should never assign high confidence to a result solely because it appears near the top of a search-results page. Record the query, provider, collection date, URL, and observed title or snippet before performing any permitted validation.

5.5 Why Indexing Controls Are Not Access Controls

A crucial defensive distinction is that `robots.txt` manages crawler behavior; it does not restrict a person who knows the URL. Similarly, `noindex` or an `X-Robots-Tag` can instruct supporting engines not to list a resource, but neither mechanism supplies authentication or authorization [12, 13].

Not indexed ≠ Not accessible

Protect confidential content at the source, not only in search results.

When documents are unintentionally exposed, the correct remediation may include removal, server-side access control, corrected permissions, revocation of exposed secrets, metadata sanitization, and a subsequent search-engine removal request. Asking an engine to delete a result without correcting the original exposure is insufficient. Moreover, if a `robots.txt` exclusion prevents a crawler from seeing a `noindex` directive, the URL may still appear as a reference in search results [13].

5.6 From Search Result to Defensible Finding

Suppose a domain-restricted search returns a publicly indexed PDF bearing an organizational name and a creation date. The tester may record the result title, source URL, query, and timestamp, then validate permitted facts without unnecessarily opening or redistributing sensitive data. The presence of an outdated report might be a documentation-hygiene issue; a public document that reveals internal operational details could require a more substantial exposure review. Its severity depends on content, accessibility, business context, and plausible impact—not on the number of matching search results.

The process is therefore **query → observe → check scope → validate → report**. OWASP's *Web Security Testing Guide*, test WSTG-INFO-01, describes search-engine reconnaissance as a structured way of discovering information leakage [9]. Webpage comments, metadata, and client-side resources are covered in WSTG-INFO-05 [10].

6 Building a Structured Footprint

A useful footprint is not a list of search results. It is a structured model of the target that separates different dimensions of exposure and records the evidence supporting each conclusion. This prevents the analyst from confusing a discovered relationship with a confirmed asset.

Dimension	Typical Questions	Examples of Evidence
Organization	What business units, locations, brands, and partners are publicly visible?	Official websites, reports, press releases, recruitment pages
Domain and DNS	Which domains, subdomains, mail systems, and name servers are associated with the organization?	RDAP, authoritative DNS, passive DNS, Certificate Transparency
Internet Exposure	Which services have been observed on public Internet-facing infrastructure?	Shodan, Censys, public scan databases, certificates
Identity	Which organizational naming patterns and authorized accounts are publicly visible or known to have breach exposure?	Company directories, public documents, theHarvester, HIBP
Technology	Which platforms, frameworks, products, and hosting providers are suggested by public evidence?	Job advertisements, repositories, headers, documentation, scan databases
Historical	What previously exposed systems or content may still matter?	Web archives, historical DNS, old certificates, archived documentation
Third Party	Which SaaS, CDN, cloud, supplier, or service-provider relationships are visible?	CNAME records, MX records, certificates, organization publications

Table 4: Dimensions of a structured reconnaissance footprint.

The analyst should avoid collapsing these dimensions too early. For example, a CNAME may show that a hostname points to a third-party SaaS provider. That observation is valuable because it identifies a dependency, but the SaaS provider is not automatically part of the penetration-test scope. Likewise, a historical certificate may reveal a once-valid hostname without proving that the service still exists.

A practical evidence record can contain five fields:

6.1 Ownership, Third-Party Services and Scope

A structured footprint must distinguish **association** from **control**. A domain registration, a certificate name, and a website link may support a relationship with the organization, yet none necessarily establishes which legal entity operates the underlying service. Cloud instances may change tenants; managed DNS and email services may be operated entirely by external providers; and an acquired organization's former domains can remain visible long after its infrastructure changes.

For each candidate asset, the analyst should record a provisional status: *confirmed in scope*, *plausibly associated—not confirmed*, *third party*, *historical*, or *out of scope*. Only the engagement owner can resolve ambiguous authorization. An asset that appears in a public intelligence platform is never automatically a permitted scanning target.

For example, suppose a university's DNS records point to a cloud mail provider, and its website names a research partner. Both relationships belong in the footprint because they describe external dependencies. Neither permits testing the cloud provider's unrelated tenants or the partner's network. This distinction is critical to producing an accurate map without expanding the legal boundaries of the assessment.



Figure 5: A structured reconnaissance evidence record linking observation, source, timestamp, scope status, and confidence.

Consider an approved domain for which three independent observations are available: a Certificate Transparency record contains a hostname, current DNS resolves that hostname, and the organization's website links to the same service. The combined evidence is stronger than any single source alone. This is the principle of **triangulation**: confidence grows when independent sources support the same conclusion.

The reverse is equally important. If an old web archive mentions a host that no longer resolves and no current organizational source references it, the correct conclusion may be "historical asset, ownership or current status unconfirmed." Professional OSINT preserves this uncertainty rather than forcing every observation into a definitive answer.



Figure 6: A structured footprint correlates organizational, domain, identity, technology, Internet-exposure, historical, and third-party evidence.

7 Widely Used Reconnaissance and OSINT Tools

Tool popularity changes over time, so it is more useful to learn **representative, widely used tools** and the problem each one solves. The following selection emphasizes the distinctive purpose of each tool, not an exhaustive inventory of products.

7.1 Registration, DNS, Passive DNS and Certificate Tools

Registration and naming data remain among the most dependable starting points because they help establish ownership and infrastructure relationships before the analyst considers more speculative OSINT.

RDAP and ICANN Lookup support current registration-data research. Utilities such as **dig** and **nslookup** can retrieve public DNS records, while passive-DNS services provide historical observations collected by third parties. Certificate Transparency search services such as **crt.sh** are useful for identifying hostnames that have appeared in public certificates.

These sources complement one another. RDAP may identify the registrar and name servers; DNS may reveal current mail and hosting relationships; certificate records may identify additional hostnames; and passive DNS may show how the infrastructure changed over time. None of these should be treated as an automatic asset inventory. Shared hosting, cloud migration, expired certificates, and domain transfers can all create misleading associations.

Tool / Service	Main Role	Typical Reconnaissance Use
Shodan	Internet-exposure search	Reviews third-party observations of Internet-connected systems, exposed services, banners, and related metadata
Censys	Internet and certificate intelligence	Searches hosts, web properties, services, and certificates to help map external exposure
RDAP / ICANN Lookup	Domain registration	Checks registrar, dates, status, and authoritative name-server information
crt.sh / CT data	Certificate Transparency	Finds certificate-associated hostnames and historical domain evidence
theHarvester	Automated OSINT collection	Collects publicly indexed domain, hostname, and email-related information from supported sources
Maltego	Link analysis	Represents entities and relationships visually for correlation and investigation
SpiderFoot	OSINT automation	Automates collection and correlation across many public data sources
OWASP Amass	Attack-surface mapping	Supports external asset discovery and domain/infrastructure mapping using open-source information and, where authorized, active techniques
Have I Been Pwned	Breach-exposure intelligence	Checks whether authorized email accounts or controlled domains appear in known breach datasets
ExifTool	Metadata analysis	Extracts document and media metadata for technical and organizational clues
Wayback Machine	Historical web content	Compares past and current public content and identifies retired pages or historical references
Exploit-DB / SearchSploit	Public exploit research	Correlates an already identified product or version with public proof-of-concept research; it is a transition toward vulnerability analysis rather than a primary OSINT source

Table 5: Representative tools and services used in modern reconnaissance.

7.2 Shodan and Censys

Shodan is a search engine for Internet-connected systems. Instead of indexing ordinary web pages, it emphasizes information observed from publicly reachable services, including service banners and related metadata. In an authorized assessment, Shodan can help a tester understand what a third-party observer has already recorded about the organization's external exposure.[1]

Censys serves a similar reconnaissance role but places strong emphasis on structured host, web-property, and certificate data. It is particularly useful when correlating IP addresses, public services, DNS names, and TLS certificate information.[2]

Neither platform proves that a discovered asset belongs to the client. Cloud infrastructure, shared hosting, reused certificates, and historical observations can produce false associations. Scope and ownership must be validated before testing continues.

7.3 Search Engines, Repositories and Web Archives

Search engines are covered in the dedicated section on Google dorking. Here the emphasis is on complementary sources: public repositories and archived websites. Search operators identify candidate information; repositories and archives help explain its origin and historical context.

Public code repositories such as GitHub and GitLab can reveal project names, programming languages, dependency files, deployment examples, and historical configuration artifacts. The correct reconnaissance task is to document public exposure and its security relevance. Discovering a secret, token, or credential in a public repository does not authorize the tester to authenticate with it.

Historical services such as the **Wayback Machine** help analysts compare current and previous versions of websites. This is valuable because organizations often remove links without immediately decommissioning every associated service. Historical information should be labelled clearly and validated against current evidence before it influences testing decisions.

7.4 theHarvester, Maltego, SpiderFoot and Amass

theHarvester automates collection of selected public information, especially domain, hostname, and email-related results. It is useful for quickly generating leads, but its output should be checked against the original sources.

Maltego focuses on link analysis. It models domains, organizations, infrastructure, people, and other entities as a graph so that the analyst can see relationships that may be difficult to recognize in a flat list.

SpiderFoot automates OSINT collection and correlation across many data sources. Its strength is breadth; its limitation is that large automated result sets can include stale or

[1] https://help.shodan.io/the-basics/what-is-shodan
[2] https://docs.censys.com/

weakly attributed data.

OWASP Amass supports attack-surface mapping and external asset discovery. It combines open-source information gathering with additional reconnaissance capabilities, some of which may be active and therefore must be used only when the Rules of Engagement permit them.[3]

7.5 Have I Been Pwned

Have I Been Pwned (HIBP) is relevant to identity-focused OSINT because it can indicate whether an email address has appeared in known data breaches. For organizations that have verified control of a domain, HIBP also provides domain-oriented capabilities.[4]

In a penetration-testing context, HIBP is not a justification for indiscriminate collection of personal breach histories. The legitimate question is whether **authorized organizational identities** have known exposure that could increase account risk or justify defensive measures such as password resets, phishing awareness, or stronger multi-factor authentication.

7.6 Exploit Database and SearchSploit

Exploit-DB is an archive of public exploits and proof-of-concept research. **SearchSploit** provides a local search interface to this material. They are not primary reconnaissance tools in the same sense as Shodan or RDAP. Their value begins after reconnaissance or enumeration has identified a product, service, or version that requires vulnerability research.[5]

For this introductory chapter, the relevant progression is:

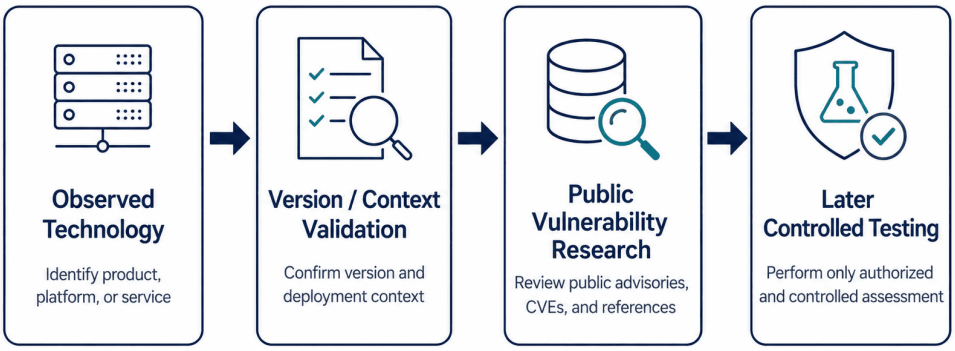


Figure 7: A structured progression from observed technology through version and context validation, public vulnerability research, and later controlled testing.

Actual exploitation belongs to the exploitation chapter and must never be performed merely because a public proof of concept exists.

[3] https://owasp.org/www-project-amass/
[4] https://haveibeenpwned.com/
[5] https://www.exploit-db.com/

7.7 Interpreting Automated Results

Automation reduces repetitive collection but can amplify attribution errors. One tool may import an old hostname from a certificate, another may retrieve a historical IP address, and a third may infer ownership from a shared hosting relationship. If these records share the same original source, they are **not independent corroboration**, even when three tools repeat them. The analyst should trace important claims back to primary evidence and record when the original observation was made.

Tool output is therefore a starting point for a reasoned investigation, not a replacement for one. Valuable results are those that can be explained, reproduced when appropriate, and linked to a decision that serves the authorized assessment objective.

8 From Reconnaissance Evidence to Testing Decisions

The objective of reconnaissance is not simply to produce an inventory. Its professional value lies in improving later testing decisions while keeping the assessment controlled.

Consider a fictional authorized assessment of `example.org` (an illustrative, non-live domain). Passive collection produces the following observations:

- RDAP confirms the approved domain and its authoritative name servers.
- DNS shows that email is handled by a third-party cloud provider.
- Certificate data identifies `vpn.example.org` and `library.example.org`.
- Shodan contains a historical observation for the VPN hostname.
- The public careers page mentions experience with a particular identity platform.
- A public PDF contains an author identifier consistent with the institution's visible email naming pattern.
- HIBP indicates that an authorized institutional account has appeared in a known breach.

A weak report would present these findings as unrelated facts. A stronger analysis asks what each observation means, how reliable it is, and what decision follows.

The VPN hostname becomes a candidate asset, but ownership and current scope must be verified. The cloud mail provider is an external dependency, not automatically a test target. The career advertisement suggests a technology hypothesis, not confirmed deployment. The document metadata may support an identity-naming pattern, but should not be used to infer unrelated personal information. The HIBP result supports a defensive identity-risk finding, not a password-guessing exercise.

After validation, reconnaissance can guide later chapters in several ways:

- confirmed hostnames can become input to authorized scanning;
- technology hypotheses can inform what service versions should be verified;

- public identity exposure can inform social-engineering risk analysis without authorizing phishing;
- third-party dependencies can be documented as external trust relationships;
- obsolete domains or documents can become defensive remediation findings even when no exploitation is required;
- a confirmed product and version can be researched in CVE sources, vendor advisories, or Exploit-DB during later vulnerability analysis.

This progression preserves an important methodological boundary:

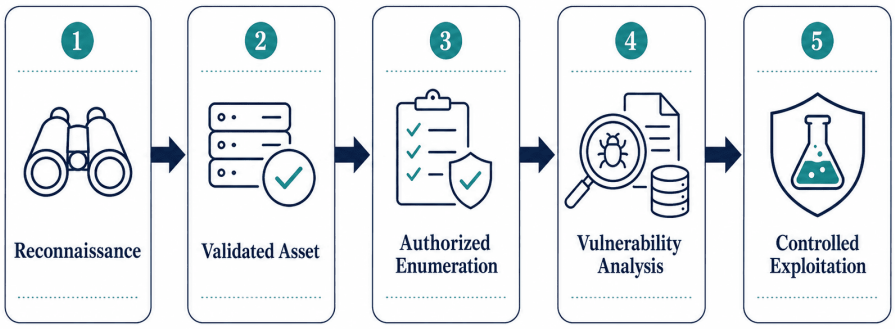


Figure 8: A structured progression from reconnaissance through validated assets, authorized enumeration, vulnerability analysis, and controlled exploitation.

Skipping the validation step is one of the most common causes of poor reconnaissance. It can lead testers to spend time on stale assets, test third-party systems outside scope, or report vulnerabilities that do not actually affect the client.

9 Reconnaissance, ATT&CK and Defensive Exposure

MITRE ATT&CK provides a useful vocabulary for describing why reconnaissance matters.

The same public information available to an ethical tester may also be available to a real adversary. Reconnaissance therefore has two complementary interpretations:

Red Team: What can an external observer learn? **Blue Team: What are we exposing unnecessarily?**

Organizations cannot eliminate all external information. DNS records, certificates, websites, business contacts, and recruitment material are often necessary. The defensive objective is to reduce unnecessary exposure by maintaining accurate asset inventories, removing obsolete documents and services, sanitizing metadata, monitoring public repositories, reviewing certificate and DNS exposure, and periodically performing defensive OSINT assessments.

ATT&CK ID	Technique	Examples
T1589	Gather Victim Identity Information	Employee names, accounts, email addresses
T1590	Gather Victim Network Information	Domains, DNS, IP addresses, external infrastructure
T1591	Gather Victim Organization Information	Roles, locations, relationships, business operations
T1593	Search Open Websites / Domains	Search engines (including defensive dorking), repositories, social and public web sources
T1596	Search Open Technical Databases	Registration data, DNS, certificates, scan databases

Table 6: Selected MITRE ATT&CK Reconnaissance techniques [4].

10 Professional Conduct and Authorized Workflow

Reconnaissance often discovers more than the original scope: related domains, cloud services, suppliers, employee personal accounts, former subsidiaries, or infrastructure with uncertain ownership. Discovery does not create authorization. Unclear assets should be recorded and submitted for scope clarification before further testing.

Public information can also become sensitive when aggregated. Assessment notes may contain employee names, infrastructure relationships, internal naming patterns, or evidence of possible weaknesses. The dataset should therefore be protected according to the engagement's evidence-handling requirements.

A concise workflow for this chapter is:

1. Confirm written authorization, target scope, and collection limits.
2. Review organization-owned public sources.
3. Collect domain-registration, DNS, certificate, and historical data.
4. Use selected OSINT platforms such as Shodan, Censys, theHarvester, Maltego, SpiderFoot, or Amass as appropriate to the intelligence question.
5. Review approved documents and metadata.
6. Check authorized identity exposure where HIBP use is appropriate.
7. Correlate results across independent sources.
8. Validate ownership, freshness, and scope.
9. Assign confidence and document the evidence.
10. Escalate uncertain or out-of-scope assets rather than testing them.

10.1 Laboratory Boundary

The practical component should use an instructor-controlled domain, explicitly approved public resources, and local laboratory files. It may practice RDAP lookups, DNS interpretation, passive OSINT collection, public document discovery, metadata extraction, relationship mapping, and source validation.

Port scanning, Nmap, vulnerability scanning, credential attacks, and exploitation are excluded from this laboratory because they are taught in later chapters.

10.2 Writing an Evidence-Based Reconnaissance Finding

A good finding identifies the observation and its limits before proposing a remedy. For example, a hypothetical result might be stated as follows:

> **Observation:** A document from the approved domain appeared in a search index on the recorded date. The indexed title and document metadata indicate an older departmental report.
> **Assessment:** Current sensitivity and ownership require confirmation. No credentials or private data were accessed.
> **Recommendation:** Review whether the document is intended for public distribution; remove unnecessary metadata and apply appropriate access or indexing controls.
> **Confidence:** Medium, pending confirmation by the content owner.

This form of reporting is more defensible than asserting a data breach from the appearance of a search result alone. When exposure is sensitive, retain the minimum necessary evidence, restrict distribution, and report through the agreed contact channel.

The governing principle is:

Collect what is necessary. Validate what is relevant. Test only what is authorized. Protect what is retained.

11 Chapter Summary

Reconnaissance is the disciplined process of understanding an authorized target before deeper technical assessment begins. Footprinting organizes the observations into a structured profile, while OSINT supplies methods for collecting and analyzing information from openly accessible sources.

The essential lessons are:

- Reconnaissance is broader than any individual tool.
- Passive, low-touch, and active methods differ mainly in their interaction with target-controlled infrastructure.

- Strong OSINT follows a cycle of definition, collection, correlation, validation, and documentation.
- RDAP, DNS, certificates, websites, repositories, documents, and historical sources are core building blocks of a target footprint.
- Shodan and Censys provide third-party visibility into Internet-facing exposure.
- theHarvester, Maltego, SpiderFoot, and Amass support automated collection, correlation, and attack-surface mapping.
- Search-engine reconnaissance and Google dorking use public search indexes; indexing controls cannot replace access controls.
- ExifTool supports metadata analysis.
- Exploit-DB and SearchSploit connect identified technologies to later vulnerability research; exploitation is outside this chapter.
- HIBP can inform authorized identity-exposure assessments, not indiscriminate collection of personal breach history.
- Findings must be validated for ownership, freshness, reliability, and scope.
- Ethical reconnaissance requires authorization, data minimization, secure evidence handling, and respect for engagement boundaries.

Good reconnaissance does not collect the most information. It collects the right information, validates it, and turns it into defensible security knowledge.

References

[1] G. Weidman, *Penetration Testing: A Hands-On Introduction to Hacking*. San Francisco, CA: No Starch Press, 2014.

[2] P. Engebretson, *The Basics of Hacking and Penetration Testing: Ethical Hacking and Penetration Testing Made Easy*, 2nd ed. Waltham, MA: Syngress, 2013.

[3] M. N. Alam and V. Laxmi, Eds., *Ethical Hacking and Cybersecurity: A Comprehensive Guide to Penetration Testing and Threat Mitigation*. Dhaka: BCRP, 2025.

[4] MITRE ATT&CK, "Reconnaissance—Tactic TA0043," Online source. Accessed: Oct. 27, 2026.

[5] K. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, *Technical Guide to Information Security Testing and Assessment*, NIST Special Publication 800-115, 2008.

[6] ICANN, "ICANN Update: Launching RDAP; Sunsetting WHOIS," Jan. 27, 2025. Online source.

[7] ICANN, "Domain Name System (DNS)." Online source.

[8] OWASP Foundation, *Web Security Testing Guide*. Online source.

[9] OWASP Foundation, "Conduct Search Engine Reconnaissance for Information Leakage," WSTG-INFO-01. Online source.

[10] OWASP Foundation, "Review Web Page Content for Information Leakage," WSTG-INFO-05. Online source.

[11] Google, "Refine Google searches," Google Search Help. Online source.

[12] Google Search Central, "Introduction to robots.txt." Online source.

[13] Google Search Central, "Block Search Indexing with noindex." Online source.

[14] OffSec, "Exploit Database and Google Hacking Database." Online source.